

Políticas: Resource-Based vs Identity-Based

Cross-Account, Evaluation Logic e Casos de Uso

AWS Certified Developer Associate

Instrutor: Marlon Anesi

Identity-Based vs Resource-Based: Comparativo

Identity-Based Policy

- Attached: users, grupos, roles
- Define O QUE o principal pode fazer
- Sem campo Principal no JSON
- Managed (AWS/Customer) ou Inline
- Ex: Attach AdministratorAccess a um role
- Necessaria para ações na própria conta
- Não funciona cross-account sozinha

Resource-Based Policy

- Attached: S3 bucket, SQS, Lambda, etc.
- Define QUEM pode acessar o recurso
- OBRIGATÓRIO campo Principal
- Sempre Inline (sem managed)
- Ex: S3 bucket policy permitindo conta B
- Permite acesso cross-account direto
- O principal não precisa de identity policy

Serviços com Resource-Based Policy + Cross-Account

Principais serviços que suportam Resource-Based Policy:

Amazon S3

Bucket Policy - controle de acesso por bucket/prefixo

AWS Lambda

Function Policy - permite outros serviços invocar a função

Amazon SQS

Queue Policy - quem pode enviar/receber mensagens

Amazon SNS

Topic Policy - quem pode publicar/subscrever

AWS KMS

Key Policy - OBRIGATÓRIO para gerenciar chaves CMK

Amazon ECR

Repository Policy - cross-account pull de imagens

Cross-Account com Resource-Based Policy:

Conta A
User / Role



Conta B
S3 Bucket + Policy

Resource-based policy SUFICIENTE para cross-account (sem assume role necessário)

Lógica de Avaliação de Permissões (IAM Evaluation)

1

Deny Explícito?

Se qualquer policy tiver Deny explícito -> NEGADO imediatamente

2

SCP (Organizations)?

Se SCP não permitir a ação -> NEGADO

3

Resource-Based?

Se resource-based policy tem Allow para o principal -> PERMITIDO

4

Permission Boundary?

Se boundary não permitir -> NEGADO

5

Identity-Based?

Se identity policy tem Allow -> PERMITIDO, senão -> NEGADO

Regra de ouro: Tudo NEGADO por padrão. Precisa de Allow explícito. Deny vence qualquer Allow.

Casos de Uso e Decisão de Qual Policy Usar

Use Identity-Based quando:

- Controlar o que um usuário/role pode fazer
- Permissões na mesma conta
- Precisa de versionamento e reutilização

Use Resource-Based quando:

- Permitir cross-account sem assume role
- Permitir serviços AWS a invocar Lambda/SQS
- KMS key policy (obrigatório)

Boas Práticas:

- Prefira resource-based policies para compartilhamento cross-account (mais simples que AssumeRole)
- Para KMS, a Key Policy é OBRIGATÓRIA - sem ela, nem o root consegue usar a chave
- Combine identity + resource-based para maior controle (ambas precisam permitir a ação)
- Use Condition para restringir por IP, MFA, horário ou tags de recurso

Pontos-chave para o Exame

1

Resource-Based tem campo Principal

Identity-Based NÃO tem Principal. Resource-Based SIM. Se a policy JSON tiver Principal -> resource-based.

2

Cross-Account com Resource-Based

Resource-based policy sozinha permite cross-account. Com AssumeRole, as duas contas precisam ter policy.

3

KMS Key Policy e Obrigatória

Para chaves CMK do KMS, a key policy é SEMPRE obrigatória. Identity policy sozinha não dá acesso.

LEMBRE-SE: Policy JSON tem campo Principal? -> resource-based. Cross-account sem AssumeRole? -> resource-based!